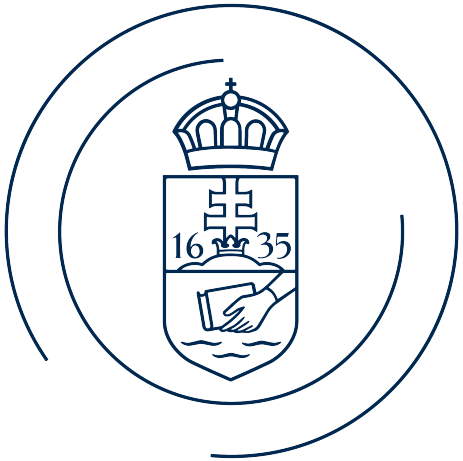


ELTE
EÖTVÖS LORÁND
UNIVERSITY

1010110100101010101110101101001010101011101110101101001010101 00

Cybersecurity Basics

Security of Embedded and IoT Devices

Introduction to Cybersecurity Challenges in the Connected World

What are Embedded Devices and IoT?



Embedded Devices

- Purpose-built computers
- Limited resources
- Real-time operations

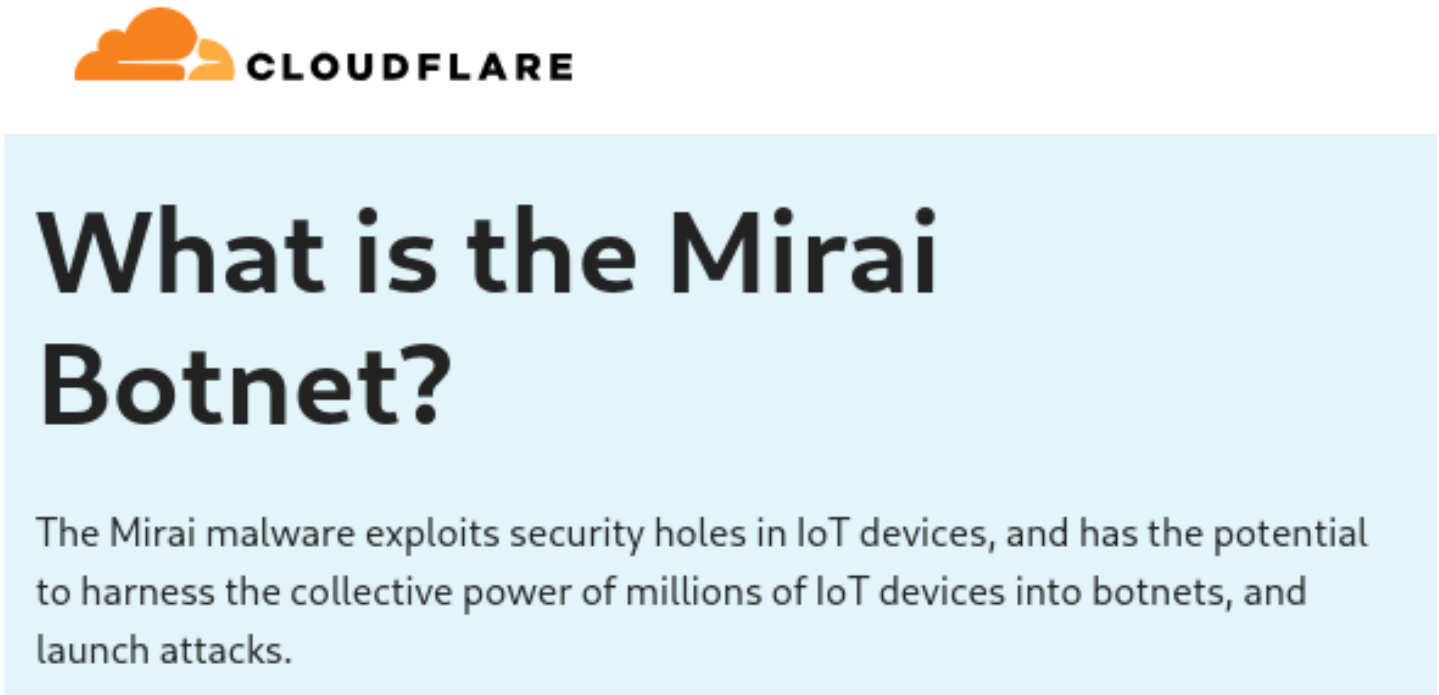
IoT Devices

- Connected embedded devices
- Internet connectivity
- Sensor integration

Examples

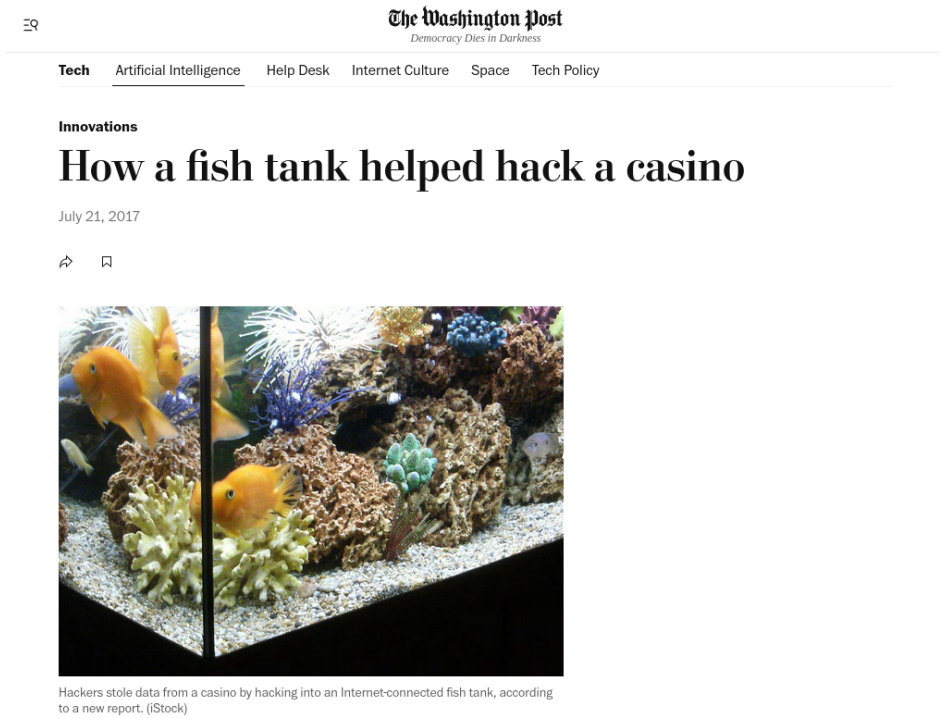
Smart home devices, industrial sensors, medical devices

Real-World IoT Security Incidents



- 2016: Mirai botnet takes down major websites

Real-World IoT Security Incidents



The Washington Post
Democracy Dies in Darkness

Tech | Artificial Intelligence | Help Desk | Internet Culture | Space | Tech Policy

Innovations

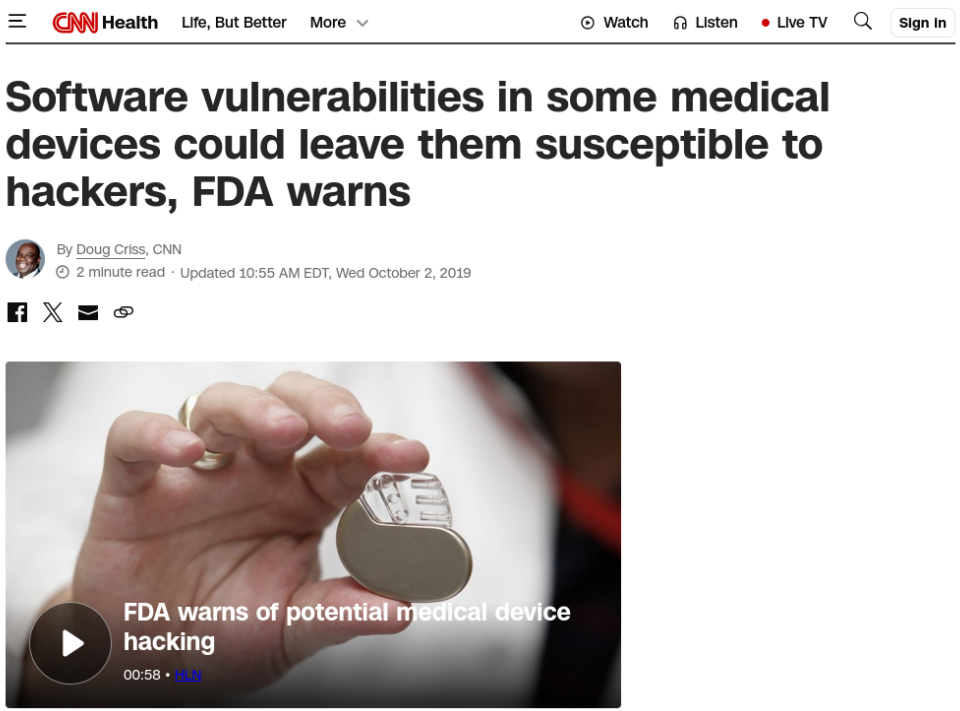
How a fish tank helped hack a casino

July 21, 2017

Hackers stole data from a casino by hacking into an Internet-connected fish tank, according to a new report. (iStock)

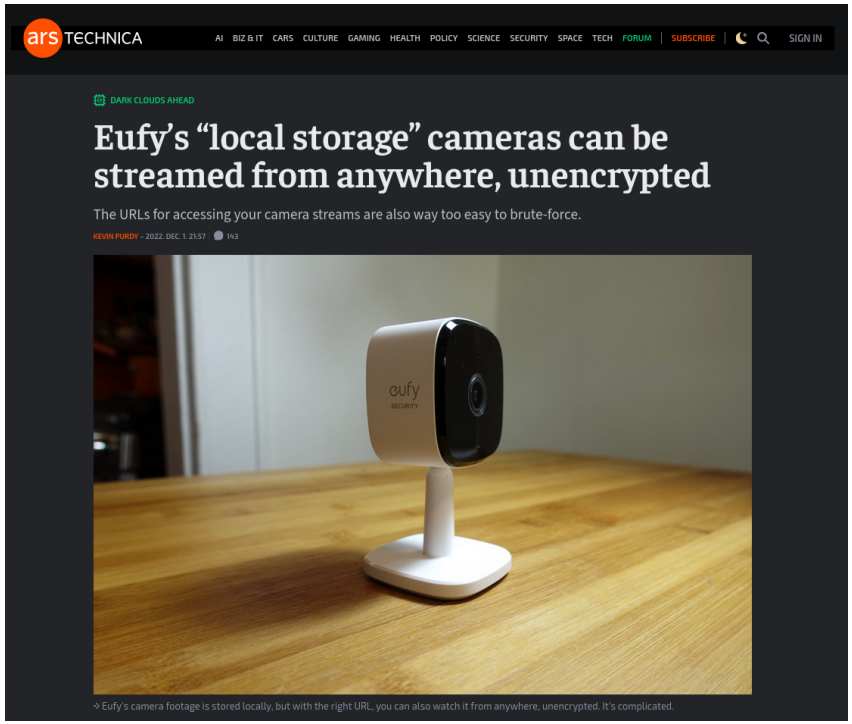
- 2016: Mirai botnet takes down major websites
- 2017: Casino hacked through IoT fish tank

Real-World IoT Security Incidents



- 2016: Mirai botnet takes down major websites
- 2017: Casino hacked through IoT fish tank
- Medical device vulnerabilities (as discussed before)

Real-World IoT Security Incidents



- 2016: Mirai botnet takes down major websites
- 2017: Casino hacked through IoT fish tank
- Medical device vulnerabilities (as discussed before)
- 2022: Eufy webcam data leak

Real-World IoT Security Incidents



Reuters

World Business Markets Sustainability More

Israel planted explosives in Hezbollah's Taiwan-made pagers, say sources

By **Laila Bassam** and **Maya Gebeily**

September 20, 2024 10:00 AM GMT+2 · Updated 4 months ago

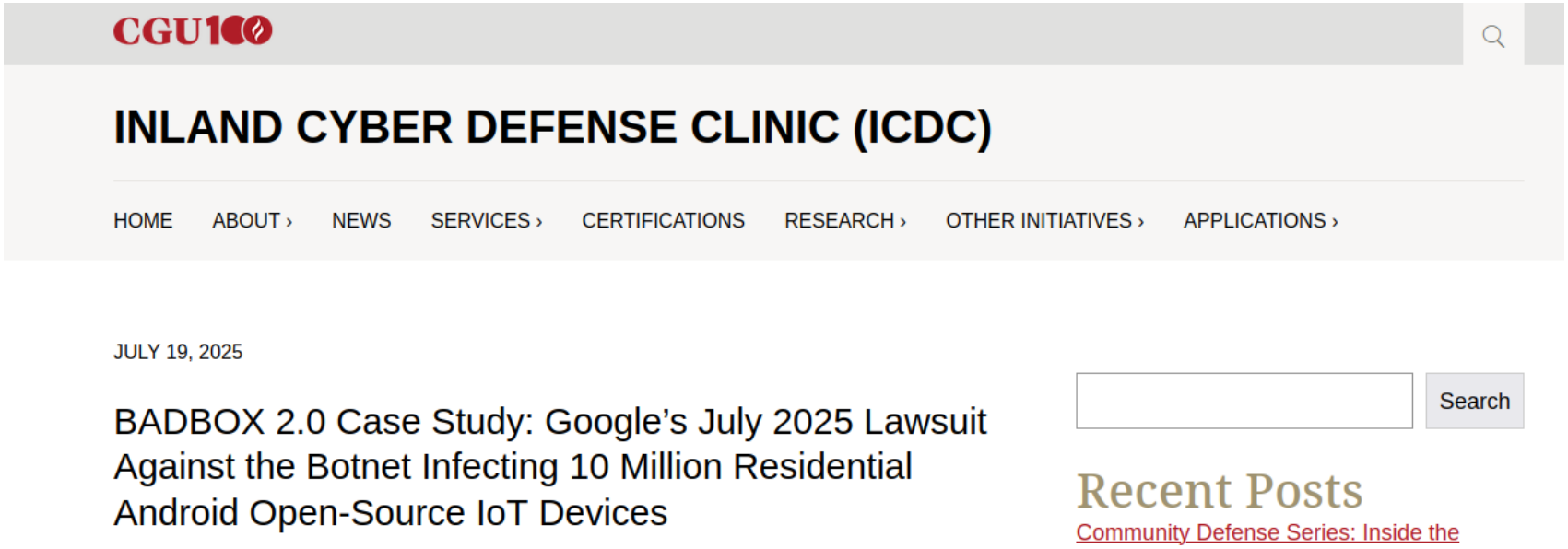
Aa

BEIRUT, Sept 18 (Reuters) - (This Sept. 18 story has been corrected to fix the pager model name to AR-924, not AP924, in paragraph 6)

Israel's Mossad spy agency planted a small amount of explosives inside 5,000 Taiwan-made pagers ordered by Lebanese group Hezbollah months before Tuesday's detonations, a senior Lebanese security source and another source told Reuters.

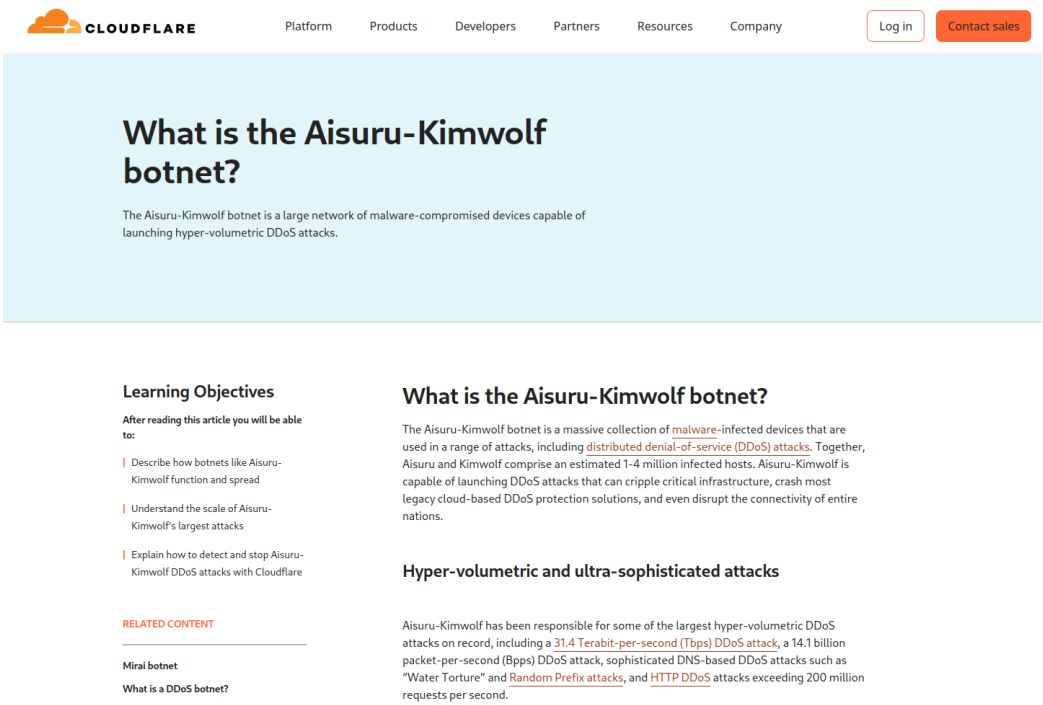
- 2024: Pagers

Real-World IoT Security Incidents



- 2024: Pagers
- 2025: BadBox 2.0
  Pre-installed backdoor on cheap Android TV boxes, **10M+ devices**

Real-World IoT Security Incidents



CLOUDFLARE

Platform Products Developers Partners Resources Company Log in Contact sales

What is the Aisuru-Kimwolf botnet?

The Aisuru-Kimwolf botnet is a large network of malware-compromised devices capable of launching hyper-volumetric DDoS attacks.

Learning Objectives

After reading this article you will be able to:

- Describe how botnets like Aisuru-Kimwolf function and spread
- Understand the scale of Aisuru-Kimwolf's largest attacks
- Explain how to detect and stop Aisuru-Kimwolf DDoS attacks with Cloudflare

RELATED CONTENT

Mirai botnet

What is a DDoS botnet?

What is the Aisuru-Kimwolf botnet?

The Aisuru-Kimwolf botnet is a massive collection of malware-infected devices that are used in a range of attacks, including distributed denial-of-service (DDoS) attacks. Together, Aisuru and Kimwolf comprise an estimated 1-4 million infected hosts. Aisuru-Kimwolf is capable of launching DDoS attacks that can cripple critical infrastructure, crash most legacy cloud-based DDoS protection solutions, and even disrupt the connectivity of entire nations.

Hyper-volumetric and ultra-sophisticated attacks

Aisuru-Kimwolf has been responsible for some of the largest hyper-volumetric DDoS attacks on record, including a 31.4 Terabit-per-second (Tbps) DDoS attack, a 14.1 billion packet-per-second (Bpps) DDoS attack, sophisticated DNS-based DDoS attacks such as "Water Torture" and Random Prefix attacks, and HTTP DDoS attacks exceeding 200 million requests per second.

- 2024: Pagers
- 2025: BadBox 2.0
- 2025–2026: Aisuru-Kimwolf Botnet
  IoT botnet; record **31.4 Tbps** DDoS attack

Threat Landscape and Security Impact

Threats

- Botnets
- Data breaches, privacy violations
- Entry point into network
- Supply chain vulnerabilities
- Physical tampering

Key Point

Security failures in IoT can cascade into widespread consequences!

Prevention

Security by design, regular updates, and following industry best practices

Challenges in Securing IoT Devices

- **Resource Constraints**: Limited processing power, memory, and energy
- **Cost**: Security features add to the bill of materials
- **Connectivity**: Always-on nature increases attack surface
- **Scale**: Billions of devices need security management

Hardware Security Considerations (Reminder)

Attack Surfaces

- Physical (JTAG, debug headers)
- Side-Channel (power analysis, EMI)
- Invasive (chip decapping, fault injection)

Protection Measures

- Secure enclosures
- Tamper-evident seals
- Protected ports
- Security fuses

IoT Communication Landscape

Short Range

- Bluetooth LE
- Zigbee
- NFC

Long Range

- WiFi
- LoRaWAN
- Cellular (4G/5G)

Each protocol brings its own security challenges and requirements!

Common IoT Vulnerabilities

- **Authentication**
  - Default passwords
  - Weak passwords
  - Hardcoded credentials
- **Network Services**
  - Unencrypted protocols
  - Insecure configurations
  - Outdated software
- **Updates & Components**
  - Insecure update mechanisms
  - Missing security patches
  - Outdated libraries
- **Data Protection**
  - Insufficient encryption
  - Insecure storage
  - Lack of physical protection

Accessing Your Smart Devices

Different methods for interacting with your devices remotely, with varying security implications:

- **Local Only Access**
  Access only from within your home network (LAN/Wi-Fi).

  ✅ Minimal attack surface
  ⚠️ No remote access

- **VPN (e.g., WireGuard, OpenVPN, Tailscale, ZeroTier)**
  Secure, encrypted tunnel into your home network.

  ✅ Encrypted traffic
  ✅ User authentication
  ✅ Only one entry point
  ✅ Mesh VPNs: simpler setup
  ⚠️ Server setup/management
  ⚠️ Additional app required
  ⚠️ Provider trust (mesh VPN)

- **Cloud Tunnels (e.g., Cloudflare Tunnel, ngrok, zrok)**
  Outbound connection to provider; proxied remote access.

  ✅ No open inbound ports
  ✅ Hides public IP
  ✅ Provider security (e.g. auth)
  ⚠️ Provider trust (can even read HTTPS traffic)
  ⚠️ Potential cost

Accessing Your Smart Devices (cont.)

Different methods for interacting with your devices remotely, with varying security implications:

- **Port Forwarding (Opening Ports)**
  Router forwards internet traffic directly to internal device.

  ✅ No third-party reliance
  ✅ Potentially lower latency
  ⚠️ Highest risk
  ⚠️ Direct internet exposure

- **Vendor Cloud (Often Default)**
  Access via manufacturer's app/portal, mediated by their servers.

  ✅ Easy setup
  ✅ No user network config
  ⚠️ Relies on vendor (cost?)
  ⚠️ Privacy concerns
  ⚠️ Vendor breach risk
  ⚠️ Service discontinuation

Secure by Design Principles

- **Security First**: Built-in, not bolted-on
- **Least Privilege**: Minimal required access
- **Defense in Depth**: Multiple security layers
- **Fail Secure**: Safe failure modes

EU Cyber Resilience Act (2022–2027)

Mandates baseline security for products sold in the EU.

- Secure default configuration
- Security updates for the product's supported lifetime
- Vulnerability disclosure obligations

Full application only by the end of 2027.

Remember

Security decisions made during design impact the entire device lifecycle!

Lessons from Security Incidents

- Default credentials enable massive botnets
- One weak device can compromise entire networks
- Poor update mechanisms leave devices exposed
- Supply chain vulnerabilities can be dangerous

Lessons from Security Incidents

- Default credentials enable massive botnets
- One weak device can compromise entire networks
- Poor update mechanisms leave devices exposed
- Supply chain vulnerabilities can be dangerous

Key Takeaway

Prevention is always cheaper than recovery!

Thank you for your attention!

Gergely Zsolt Kovács

 kovacsg@inf.elte.hu